Activity 4 Report: Database Users, Roles, Privileges and Access Control

COMP 018 Database Administration | Project tested: PUP-SPOT Campus Lost and Found (PHP + PostgreSQL) | Date of testing: 6 November 2026

1. Cover and links

Item	Value
Testing group	G08: Borreta, Joshua; Bola, Martin Lawrence; Juatchon, Joaquin Phillip; Marcos, Karl Raphael; Pacheco Jr., Sancho; Vera Cruz, Euan Joseph
Project tested	PUP-SPOT Campus Lost and Found
Owning group	Group 05 (grp05-dba)
Repository	https://github.com/grp05-dba/grp05_lostandfound
Tracker	https://github.com/EclipseChan/bwisIT-Solutions---Campus-Canteen-Pre-Order-and-Queue-Management-System/tree/main/other_group_tests
Evidence files	a4_access_tests.txt, a3_deploy.txt, a3_app.txt

2. Access-control plan (from the project SQL and docs)

Two login roles. lostandfound_app is used by the admin server: SELECT, INSERT and UPDATE on all tables, plus DELETE on the three image tables and potential_matches. lostandfound_public is used by the public server: SELECT on items, categories, reports, claims, matches and two image tables, INSERT on reports, claims, matches and image tables, UPDATE on lost_reports.status only, and DELETE on potential_matches. Neither role has DELETE on items, claims or reports, and neither can create objects.

3. Privilege matrix (S select, I insert, U update, D delete)

Table	lostandfound_app	lostandfound_public
categories	SIU-	S---
claim_images	SIUD	-I--
claims	SIU-	SI--
item_images	SIUD	S---
items	SIU-	S---
lost_report_images	SIUD	SI--
lost_reports	SIU-	SI-- (plus UPDATE on status only)
potential_matches	SIUD	SI-D

4. Verification results

Each test used a real login with the role's password through psql. Write tests used WHERE false or a rolled-back transaction, so no data changed.

Role	Test	Expected	Actual

public	SELECT items	Allowed	Allowed (7 rows)
public	SELECT lost_reports and claims with names, student numbers, emails, phones	Not clear from plan	Allowed, all rows readable (issue 1)
public	INSERT claim (rolled back)	Allowed	Allowed
public	UPDATE lost_reports.status	Allowed	Allowed
public	UPDATE lost_reports.title	Denied	Denied (column-level grant works)
public	UPDATE claims.status	Denied	Denied
public	INSERT or UPDATE items	Denied	Denied
public	DELETE lost_reports	Denied	Denied
public	DELETE potential_matches	Allowed	Allowed
public	SELECT claim_images	Denied	Denied
public	CREATE TABLE, CREATE ROLE, DROP TABLE	Denied	Denied for all three
public	See other sessions in pg_stat_activity	Query text hidden	11 sessions visible, text of 1 (its own)
app	SELECT claims	Allowed	Allowed
app	UPDATE claims and items	Allowed	Allowed
app	DELETE items, claims, lost_reports	Denied	Denied for all three
app	DELETE item_images, potential_matches	Allowed	Allowed
app	CREATE TABLE, DROP TABLE, CREATE ROLE	Denied	Denied for all three
app	VACUUM	Not in plan	Skipped with "permission denied to vacuum"
both	Connect to other databases (canteen_db, postgres)	Denied	Denied
public	Login with a wrong password	Rejected	Rejected (FATAL: password authentication failed)

Both roles are non-superuser with no CREATEDB or CREATEROLE. The table owner is postgres. Application check (Activity 3): the public server uses lostandfound_public and the admin server uses lostandfound_app. The public server returns 404 for admin routes.

5. Issues and recommendations

#	Finding	Recommendation
1	lostandfound_public can SELECT every row of lost_reports and claims, including full_name, student_number, email and phone_number. The application only returns one record per code, but anyone holding the public credentials (in .env on the public server) can read all personal data	Grant column-level SELECT without the personal columns, or move lookups behind a function that takes the code
2	lostandfound_public can DELETE all of potential_matches and INSERT matches with any score	Use a function for removing a match that checks the report code, and keep match creation on the admin role
3	lostandfound_app can UPDATE every column of claims, items and reports, including claim_code, and can INSERT and UPDATE categories	Use column-level grants for the columns that staff actually change
4	The admin console has no login, and all staff share one database role	Add application accounts or at least a per-person audit of who approved a claim
5	No audit trail: the database has no	Add triggers that record claim and item

	triggers and no audit table	status changes
6	PUBLIC keeps CONNECT and TEMP on the database (datacl starts with =Tc)	REVOKE ALL ON DATABASE grp05_lostandfounddb FROM PUBLIC
7	No maintenance or backup role exists, so VACUUM and pg_dump need the superuser	Create roles with pg_maintain and pg_read_all_data

Good points: the schema is closed to DDL, deletes are blocked on the main tables, the public role is genuinely limited, and passwords are required.

6. Feedback to owners

Sent on 6 November 2026: findings 1 to 6.

7. Limitations

Write tests changed no data. Authentication of staff is not a database matter in this project, so it is listed only as a finding.

AI usage declaration

- Tool: Claude (Anthropic).
- Tasks: interpreting the results of the testing.
- Validation: the commands were run by the group on its own server, and every result in this report comes from the saved output files.